Требования к программному обеспечению

при сборе, обработке и хранении персональных данных

Применимо к: Windows / Linux / macOS • любая СУБД • домашний сервер / ноутбук / облако

Правовая база:

Закон РБ № 99-З от 07.05.2021 «О защите персональных данных»
Приказ ОАЦ № 66 от 20.02.2020 (техническая и криптографическая защита)
Закон РБ № 455-З от 10.11.2008 «Об информации, информатизации и защите информации»

© Яковчик Алексей Юрьевич +375447457242

От 22 июня 2026
Республика Беларусь



1.Введение

Настоящий документ формулирует технические, организационные и правовые требования к программному обеспечению, аппаратной части и сетевой инфраструктуре, которые применяются при сборе, хранении и обработке персональных данных (далее – перс. данные). Требования носят универсальный характер и не зависят от операционной системы (*Windows*, *Linux, macOS*), типа используемой СУБД (реляционные, документоориентированные, *in-memory*), архитектуры развёртывания (домашний сервер, корпоративная инфраструктура, облако, персональный ноутбук) или применяемого стека разработки.

Под оператором в настоящем документе понимается любое физическое лицо, индивидуальный предприниматель, организация или государственный орган, самостоятельно или совместно с иными лицами организующие и/или осуществляющие обработку перс. данных.

> *Обработка перс. данных – любое действие или совокупность действий: сбор, систематизация, хранение, изменение, использование, обезличивание, блокирование, распространение, предоставление, удаление. (ст. 1, Закон о перс. данных, №99-З)*

Правовую основу составляют:

- Закон Республики Беларусь от 7 мая 2021 г. № 99-З «О защите персональных данных»
- Приказ ОАЦ при Президенте РБ от 20 февраля 2020 г. № 66 «О мерах по реализации Указа Президента РБ от 09.12.2019 № 449» (техническая и криптографическая защита информации)
- Закон РБ от 10 ноября 2008 г. № 455-З «Об информации, информатизации и защите информации»
- Ст. 23.7 КоАП Республики Беларусь (административная ответственность)

2. Требования к сбору персональных данных

2.1 Принцип минимизации данных

Сбор перс. данных допускается исключительно в объёме, необходимом для достижения конкретной, заранее заявленной цели. Сбор данных «про запас» является нарушением закона независимо от используемой технологии или платформы.

> *Обработка перс. данных должна быть соразмерна заявленным целям их обработки и обеспечивать на всех этапах справедливое соотношение интересов всех заинтересованных лиц.*
> *(ст. 4, Закон №99-З)*

Требования к ПО:

- Пользовательские интерфейсы (формы, API, мобильные приложения) запрашивают только те поля, которые прямо необходимы для функционирования системы
- Необязательные поля явно помечены; их заполнение не блокирует использование сервиса
- Сбор технических метаданных (IP, user-agent, геолокация) допускается только при наличии обоснования и согласия
- Скрытый или фоновый сбор данных без ведома пользователя – запрещён
- Сбор специальных категорий перс. данных (здоровье, биометрия, расовая принадлежность, судимость) требует отдельного явного согласия и повышенных мер защиты

2.2. Цель обработки

Для каждой собираемой категории данных должна быть задокументирована конкретная цель. Использование данных не по заявленной цели без нового согласия пользователя – нарушение закона.

Требование	Описание / способ реализации	Правовое основание
Идентификационные данные (ФИО)	Идентификация пользователя в системе	ст. 4, Закон №99-З
Контактные данные (*email*, телефон)	Аутентификация, уведомления, связь	ст. 4, Закон №99-З

Требование	Описание / способ реализации	Правовое основание
Должность, организация	Разграничение доступа, персонализация	ст. 4, Закон №99-З
IP-адрес, логи действий	Безопасность, расследование инцидентов	Приказ ОАЦ №66
Платёжные данные	Проведение транзакций – только через сертифицированные платёжные шлюзы	ст. 17, Закон №99-З

2.3. Получение согласия

Согласие субъекта является обязательным правовым основанием для обработки перс. данных и должно быть зафиксировано системой.

> *Согласие субъекта перс. данных представляет собой свободное, однозначное, информированное выражение его воли, посредством которого он разрешает обработку своих перс. данных.*
> *(ст. 5, Закон №99-З)*

Требования к ПО независимо от платформы:

- Согласие выражается явным действием пользователя – непредзаполненный чекбокс, кнопка подтверждения
- Текст согласия содержит: наименование оператора, перечень собираемых данных, цели, срок хранения, права субъекта
- Ссылка на Политику обработки перс. данных присутствует в тексте согласия
- Факт согласия фиксируется в хранилище: идентификатор субъекта, дата/время, версия текста согласия, *IP* или идентификатор устройства
- Продолжение использования сервиса без согласия – невозможно (валидация на уровне бэкенда, не только фронтенда)
- Отзыв согласия должен быть доступен пользователю в любой момент

2.4. Требования к формам ввода

- Поля формы валидируются на длину, формат, допустимые символы – до записи в хранилище
- Все данные, введённые пользователем, проходят санитизацию (удаление управляющих символов, *HTML*-тегов) перед обработкой
- *CAPTCHA* или иная защита от автоматизированного сбора данных на публичных формах
- Форма не передаёт перс. данные в *URL*-параметрах (только через тело *POST*/*PUT* запроса)

3. Требования к хранению персональных данных

3.1. Срок хранения

> *Хранение перс. данных должно осуществляться не дольше, чем этого требуют заявленные цели обработки. (ст. 4 ч. 8, Закон №99-З)*

Требования к ПО:

- В системе реализован механизм автоматического удаления или обезличивания данных по истечении установленного срока
- Срок хранения задокументирован для каждой категории данных в Реестре обработки перс. данных
- При удалении аккаунта пользователем – перс. данные физически удаляются или необратимо обезличиваются
- Резервные копии (бэкапы) также подчиняются срокам хранения: устаревшие бэкапы, содержащие перс. данные, подлежат уничтожению
- Логи, содержащие перс. данные, должны иметь ограниченный срок ротации

3.2. Защита данных в хранилище (*at rest*)

Независимо от типа СУБД (реляционная, документоориентированная, ключ-значение, файловая система) перс. данные должны быть защищены от несанкционированного доступа.

Требование	Описание / способ реализации	Правовое основание
Пароли и секреты пользователей	Хранить исключительно в виде хэша с солью. Допустимые алгоритмы: *bcrypt* (*cost* ≥ 12), *argon2id, scrypt*. Запрещены: *MD5*, *SHA-1, SHA-256* без соли, обратимое шифрование.	Приказ ОАЦ №66; ст. 17, Закон №99-З
Перс. данные в СУБД	Шифрование на уровне столбца (*column-level encryption*) или прозрачное шифрование хранилища (*TDE*). Алгоритм: *AES-256*.	Приказ ОАЦ №66

Требование	Описание / способ реализации	Правовое основание
Перс. данные в файлах	Файлы с перс. данными (*CSV, JSON, XML*, документы) шифруются. Незашифрованное хранение на диске – запрещено.	Приказ ОАЦ №66
Токены, API-ключи, сессии	Хранить хэш токена (*SHA-256*), не сам токен. Токены в открытом виде в БД – запрещены.	Приказ ОАЦ №66
Резервные копии	Архивы бэкапов шифруются (*AES-256, GPG*). Ключи шифрования хранятся отдельно от самих бэкапов.	Приказ ОАЦ №66
Ключи шифрования	Ключи не хранятся в том же хранилище, что и зашифрованные данные. Рекомендуется использовать менеджер секретов (*Vault, KMS*).	Приказ ОАЦ №66

3.3. Разграничение доступа к хранилищу

Принцип наименьших привилегий (*least privilege*) применяется ко всем компонентам, имеющим доступ к перс. данным, независимо от типа используемой СУБД или ОС.

- Каждый компонент системы (веб-приложение, фоновые задачи, сервис отчётов) подключается к СУБД от имени отдельного пользователя с минимальными необходимыми правами
- Системный суперпользователь СУБД (*root, postgres, sa, admin*) не используется в рабочем приложении
- *DDL*-операции (создание/изменение/удаление таблиц, миграции схемы) выполняются от имени отдельного технического пользователя, недоступного приложению
- Пароли и строки подключения к хранилищу хранятся в переменных среды или в системе управления секретами, не в исходном коде
- СУБД принимает подключения только с локального хоста или из доверенной сети, не из публичного интернета
- Файлы данных СУБД на диске доступны только системному пользователю, от имени которого работает СУБД

3.4. Журналирование (аудит доступа)

Система должна вести журнал событий, связанных с доступом к перс. данным, обеспечивая возможность расследования инцидентов, при этом сами перс. данные в логах минимизируются.

- Фиксируются: дата и время события, идентификатор субъекта (не ФИО), тип операции (чтение, создание, изменение, удаление), идентификатор инициатора, результат
- В логах не хранятся в открытом виде: пароли, токены, номера документов, полные ФИО, платёжные реквизиты
- Журналы хранятся на отдельном носителе или в отдельной системе, изолированной от основного хранилища данных
- Доступ к журналам – только у уполномоченного администратора
- Журналы защищены от изменения и удаления (*append-only*, либо контроль целостности)
- Срок хранения журналов определяется документально и не превышает необходимого

3.5. Обезличивание данных

При необходимости дальнейшей обработки данных (аналитика, тестирование, передача третьим лицам) применяется обезличивание.

> *Методы обезличивания перс. данных: введение идентификаторов, изменение состава, декомпозиция, перестановка, зашифрование. (Приказ ОАЦ №66, приложение 5)*

- Тестовые и разрабатываемые среды не должны содержать реальных перс. данных – используются синтетические или обезличенные наборы
- Аналитические выгрузки содержат обезличенные или агрегированные данные

4. Требования к сетевой инфраструктуре

4.1. Шифрование передачи данных

> *При передаче перс. данных по каналам связи применяются средства криптографической защиты информации, обеспечивающие конфиденциальность и контроль целостности.*
> *(Приказ ОАЦ №66)*

Требование	Описание / способ реализации	Правовое основание
Веб-приложения и *API*	Весь трафик – исключительно по *HTTPS*. Минимальная версия: *TLS 1.2*, рекомендуется *TLS 1.3*. Незашифрованный *HTTP* для передачи перс. данных – запрещён.	Приказ ОАЦ №66
Перенаправление *HTTP → HTTPS*	Все *HTTP*-запросы автоматически перенаправляются на *HTTPS* (код 301 или 308). *HSTS*-заголовок: *Strict-Transport-Security: max-age=31536000.*	Приказ ОАЦ №66; OWASP
Мобильные приложения	Обмен данными с сервером – только по *TLS 1.2+*. *Certificate pinning* рекомендуется для критичных приложений.	Приказ ОАЦ №66
Межсервисное взаимодействие	Взаимодействие между микросервисами, демонами, фоновыми задачами, содержащее перс. данные, – только по защищённому каналу (*TLS, VPN, SSH*-туннель).	Приказ ОАЦ №66
Подключение к СУБД	Если СУБД и приложение работают на разных хостах – соединение через *TLS* или *SSH*-туннель. Передача перс. данных по незащищённому каналу между хостами – запрещена.	Приказ ОАЦ №66

Требование	Описание / способ реализации	Правовое основание
Электронная почта с перс. данными	Передача перс. данных по *email* допускается только через *TLS* (*STARTTLS email* или *SMTPS*). Отправка перс. данных в теле нешифрованного письма – не рекомендуется.	ст. 17, Закон №99-З

4.2. Сетевая изоляция

Компоненты системы, содержащие перс. данные, должны быть максимально изолированы от публичных сетей. Принцип: открыто только то, что необходимо.

- Межсетевой экран (*firewall*) на уровне ОС или сетевого оборудования: закрыты все порты, не требующиеся для работы сервиса
- СУБД не принимает входящих подключений из публичного интернета ни при каких обстоятельствах
- Административные интерфейсы (панели управления СУБД, мониторинг, *SSH*) доступны только из доверенной сети или через *VPN*
- Для удалённого администрирования сервера с перс. данными используется *VPN* или *SSH* с аутентификацией по ключу (парольная аутентификация *SSH* – отключена)
- Сетевая сегментация: база данных с перс. данными располагается в отдельном сетевом сегменте (*VLAN*, подсеть), изолированном от публичной зоны
- Исходящие соединения от сервера с перс. данными ограничены белым списком разрешённых адресов/портов

4.3. Защита от сетевых атак

Системы, принимающие перс. данные из внешних сетей, должны быть защищены от типовых классов атак:

- *SQL*-инъекции (*SQLi*): все запросы к СУБД выполняются через параметризованные запросы или *ORM*; конкатенация пользовательского ввода в тело *SQL*-запроса – запрещена
- Межсайтовый скриптинг (*XSS*): экранирование всех данных, выводимых в *HTML*; *Content-Security-Policy* заголовок

• Межсайтовая подделка запросов (*CSRF*): *CSRF*-токены на все изменяющие состояние запросы

• Перебор паролей (*Brute force*): ограничение числа попыток входа (*rate limiting*), временная блокировка учётной записи или *IP* после *N* неудачных попыток

• Атаки на сессии: короткий *TTL* сессий, инвалидация при выходе, привязка сессии к *IP/user-agent* при необходимости

• Инъекции заголовков, открытые редиректы, *SSRF*: валидация всех входящих данных на уровне приложения

Мониторинг	Рекомендуется вести мониторинг аномальной активности: нетипичные объёмы запросов к СУБД, множественные неудачные попытки входа, массовое скачивание данных. Для систем класса 3-бг и 3-дсп по Приказу ОАЦ №66 *EDR*-системы обязательны с 01.03.2025.

4.4. *DNS* и домен

Требования к *DNS* и домену:

• Доменное имя, используемое для сервиса с перс. данными, защищено от угона (двухфакторная аутентификация у регистратора, *DNSSEC* рекомендуется)

• Все поддомены сервиса работают через *HTTPS*

• Сертификат *TLS* актуален; настроено автоматическое обновление

5. Требования к аппаратной части и физической безопасности

5.1. Физический доступ

Физическая безопасность оборудования, на котором хранятся и обрабатываются перс. данные, является обязательным условием их защиты вне зависимости от типа устройства.

Требование	Описание / способ реализации	Правовое основание
Серверное оборудование	Размещается в помещении с ограниченным физическим доступом (серверная, запираемый шкаф). Доступ фиксируется.	Приказ ОАЦ №66
Рабочие станции и ноутбуки	Автоматическая блокировка экрана при бездействии (не более 5–10 мин). Запрет входа без аутентификации.	Приказ ОАЦ №66
Съёмные носители	*USB*-накопители, внешние диски с перс. данными используют шифрование. Политика: минимальное использование съёмных носителей для перс. данных.	Приказ ОАЦ №66
Вывод оборудования из эксплуатации	Перед утилизацией или передачей: гарантированное затирание данных (многократная перезапись, NIST 800-88) или физическое уничтожение носителя.	ст. 17, Закон №99-З; Приказ ОАЦ №66
Принтеры, МФУ	Документы с перс. данными не оставляются в лотке принтера. МФУ с внутренним хранилищем – очищаются перед выводом из эксплуатации.	ст. 17, Закон №99-З

5.2. Шифрование дисков (полнодисковое)

Устройства, на которых хранятся перс. данные, должны применять шифрование всего диска или отдельных томов с данными. Требование применимо к любой ОС:

- *Windows: BitLocker* (*TPM* + *PIN* рекомендуется)
- *macOS: FileVault 2*
- *Linux: LUKS (dm-crypt)* для разделов с данными

• Мобильные устройства: шифрование устройства (включено по умолчанию в *iOS, Android 6.0+*)

• Ключ шифрования диска не хранится на том же носителе, что и зашифрованные данные

• Бэкап ключей восстановления хранится в защищённом месте, отдельном от устройства

5.3. Резервное копирование

Резервные копии содержат перс. данные и подпадают под те же требования защиты, что и основное хранилище.

• Бэкапы шифруются до записи на носитель (*AES-256, GPG* или средствами ОС)

• Носители с бэкапами хранятся физически отдельно от основного оборудования

• Доступ к бэкапам – только у авторизованных лиц, фиксируется в журнале

• Регулярная проверка восстановления из резервной копии (тестовое восстановление)

• Устаревшие бэкапы, содержащие перс. данные, уничтожаются безопасным способом

• Облачные хранилища для бэкапов: только сервисы с шифрованием на стороне клиента (*client-side encryption*) или *E2EE*

5.4. Обновления и управление уязвимостями

• Операционная система получает обновления безопасности своевременно (не позднее 30 дней после выхода критических патчей)

• СУБД, веб-сервер, среда выполнения (*runtime*), зависимости приложения поддерживаются в актуальном состоянии

• Используются только версии ПО, находящиеся на поддержке вендора (*no EOL software*)

• Все неиспользуемые сервисы, демоны и приложения отключены и удалены

• Ведётся реестр программного обеспечения (*software inventory*) для отслеживания версий и уязвимостей

• Сканирование на известные уязвимости (*CVE*) проводится периодически

6. Требования к программному обеспечению и взаимодействию

6.1. Аутентификация

Доступ к системам, содержащим перс. данные, должен осуществляться только через надёжные механизмы аутентификации, независимо от платформы и способа развёртывания.

Требование	Описание / способ реализации	Правовое основание
Парольная политика	Минимальная длина пароля: 8 символов. Проверка на распространённые пароли. Принудительная смена при компрометации. Запрет на хранение паролей в открытом виде в любых системах.	ст. 17, Закон №99-З; Приказ ОАЦ №66
Многофакторная аутентификация (MFA)	Обязательна для административных аккаунтов, имеющих доступ к перс. данным. Для пользовательских аккаунтов – настоятельно рекомендуется. Методы: *TOTP (RFC 6238)*, аппаратный ключ (*FIDO2/WebAuthn*).	Приказ ОАЦ №66 (усиленная аутентификация)
Сессии	Сессионный идентификатор: криптографически случайный, минимум 128 бит энтропии. Атрибуты *cookie: HttpOnly, Secure, SameSite=Strict*. Инвалидация при выходе.	OWASP; Приказ ОАЦ №66
Токены доступа (*JWT* и аналоги)	Алгоритм подписи: *RS256, ES256* или аналог асимметричного алгоритма. Срок жизни *access*-токена: не более 15–60 минут. *Refresh*-токен – ротируется при каждом обновлении.	OWASP
Сброс пароля	Токен сброса: одноразовый, *TTL* не более 1 часа, инвалидируется немедленно после	OWASP

Требование	Описание / способ реализации	Правовое основание
	использования. Отправляется только на заранее зарегистрированный контакт.	
Блокировка учётной записи	После *N* неудачных попыток (рекомендуется: 5–10) – временная блокировка или *CAPTCHA*. Уведомление пользователя о подозрительной активности.	Приказ ОАЦ №66

6.2. Авторизация и разграничение доступа

- Принцип наименьших привилегий: каждый пользователь и каждый компонент системы имеет доступ только к тем перс. данным, которые необходимы для его функции
- Разграничение ролей (*RBAC* или *ABAC*): разные роли имеют разный уровень доступа к данным
- Проверка прав авторизации выполняется на уровне сервера (бэкенда), а не только на клиентской стороне
- Прямой доступ к объектам по идентификатору (*IDOR*) защищён: система проверяет, принадлежат ли запрошенные данные текущему авторизованному пользователю
- Административный интерфейс недоступен рядовым пользователям системы

6.3. Безопасность кода приложения

Требования применимы ко всем языкам программирования и фреймворкам:

- Все входящие данные (из форм, *API*, файлов, заголовков *HTTP*) проходят валидацию и санитизацию до использования
- Запросы к СУБД выполняются через параметризованные запросы или *ORM*; динамическое формирование *SQL* из пользовательского ввода – запрещено
- Зависимости приложения (библиотеки, пакеты) проверяются на наличие известных уязвимостей перед использованием в продуктиве
- Секреты (пароли, ключи *API*, строки подключения) не хранятся в исходном коде и не попадают в системы контроля версий

• Обработка ошибок не раскрывает пользователю внутренние детали системы (стек вызовов, структуру БД, пути файловой системы)

• Зависимости с известными критическими уязвимостями (*CVE* с *CVSS* ≥ 7.0) обновляются или заменяются в приоритетном порядке

6.4. API и интеграции

• Все *API*-эндпоинты, возвращающие перс. данные, защищены аутентификацией и авторизацией

• *API* возвращает только те поля перс. данных, которые запрошены и необходимы – избыточные данные в ответе исключены

• Перс. данные не передаются в *URL*-параметрах (*GET*-строке) – только в теле запроса или заголовках

• *Rate limiting* настроен на все публичные *API*-эндпоинты

• Версионирование *API*: изменения в составе обрабатываемых данных требуют пересмотра согласия

• *Webhooks* и колбэки, содержащие перс. данные, доставляются только по *HTTPS* с проверкой подписи

6.5. Передача перс. данных третьим лицам

> *Предоставление перс. данных – действия, направленные на ознакомление с перс. данными определённого лица или определённого круга лиц. (ст. 1, Закон №99-З)*

• Передача перс. данных третьим лицам (аналитические сервисы, рекламные платформы, облачные провайдеры, платёжные шлюзы) допускается только с явного согласия пользователя

• Договор об обработке перс. данных заключается с каждым третьим лицом, получающим данные

• Передача осуществляется только по защищённым каналам (*TLS*)

• В запросах к внешним сервисам перс. данные не включаются в *URL*; только в теле запроса

• Третьи лица, которым передаются данные, должны соответствовать требованиям законодательства об обработке перс. данных

6.6. Права субъекта перс. данных – реализация в ПО

Следующие права пользователя являются законодательно обязательными и должны быть реализованы в системе независимо от её архитектуры:

Требование	Описание / способ реализации	Правовое основание
Право на доступ к своим данным	Пользователь может получить все свои перс. данные, обрабатываемые системой. Реализация: личный кабинет, эндпоинт экспорта данных.	ст. 10, Закон №99-З
Право на исправление	Пользователь может изменить неточные или неполные перс. данные. Реализация: редактируемый профиль.	ст. 11, Закон №99-З
Право на удаление	Пользователь может потребовать удаления своих перс. данных. Реализация: функция «Удалить аккаунт» с реальным удалением или необратимым обезличиванием.	ст. 14, Закон №99-З
Право на отзыв согласия	Пользователь может в любой момент отозвать согласие на обработку. После отзыва – обработка прекращается, данные удаляются, если нет иного правового основания.	ст. 5, Закон №99-З
Право на ограничение обработки	Пользователь может потребовать прекращения части операций с данными (например, запретить маркетинговые рассылки). Реализация: настройки уведомлений и приватности.	ст. 12, Закон №99-З
Срок исполнения требований	Оператор обязан выполнить требование субъекта в течение 15 дней с момента его получения.	ст. 15, Закон №99-З

7. Организационные и документальные требования

7.1. Обязательные документы

Оператор перс. данных (в том числе физическое лицо) обязан разработать, поддерживать в актуальном состоянии и при необходимости публиковать следующие документы:

1. Политика обработки перс. данных – публикуется на сайте или ином ресурсе в открытом доступе. Содержит: цели и правовые основания обработки, категории данных, сроки хранения, перечень третьих лиц, права субъектов, контактные данные оператора.

2. Форма согласия на обработку перс. данных – с описанием состава данных, целей, сроков, условий отзыва.

3. Реестр обработки перс. данных – внутренний документ: какие данные собираются, с какой целью, где хранятся, кто имеет доступ, сроки хранения, третьи лица.

4. Акт отнесения информационной системы к классу типовых ИС – в соответствии с Приказом ОАЦ №66.

5. Политика информационной безопасности – описывает технические и организационные меры защиты, принятые в системе.

6. Журнал учёта инцидентов – фиксация фактов несанкционированного доступа, утечек, нарушений.

7.2. Классификация информационной системы

> *В соответствии с приложением 1 к Приказу ОАЦ №66 установлены классы типовых ИС. Физические лица – собственники ИС с перс. данными вправе самостоятельно создавать системы защиты информации без привлечения специализированной организации. (Приказ ОАЦ №66, п. 4)*

Требование	Описание / способ реализации	Правовое основание
Класс 4-ин	Перс. данные (кроме специальных) без подключения к открытым каналам (интернет). Пример: локальная БД без внешнего доступа.	Приказ ОАЦ №66, Прил. 1

Требование	Описание / способ реализации	Правовое основание
Класс 3-ин	Перс. данные (кроме специальных) с подключением к интернету. Пример: веб-сайт с регистрацией пользователей, интернет-магазин.	Приказ ОАЦ №66, Прил. 1
Класс 4-спец / 3-спец	Специальные перс. данные (здоровье, биометрия, судимость и др.) без / с доступом в интернет. Повышенные требования.	Приказ ОАЦ №66, Прил. 1
Класс 4-бг / 3-бг	Биометрические и генетические перс. данные. Наивысший уровень требований. С 01.03.2025 – обязательны *EDR*-системы.	Приказ ОАЦ №66, Прил. 1; Приказ ОАЦ №259

7.3. Реагирование на инциденты

При выявлении инцидента, связанного с несанкционированным доступом к перс. данным или их утечкой, оператор обязан:

- Зафиксировать факт инцидента в журнале учёта
- Принять меры по локализации и устранению угрозы
- Уведомить субъектов перс. данных, чьи данные были скомпрометированы
- При необходимости – уведомить Национальный центр защиты перс. данных РБ
- Провести анализ причин и принять меры по предотвращению повторения

7.4. Ответственность

> *Статья 23.7 КоАП РБ: административная ответственность – штраф до 200 базовых величин за: незаконный сбор, обработку, хранение или предоставление перс. данных; умышленное незаконное распространение перс. данных; несоблюдение мер обеспечения защиты перс. данных.*

7. Сводный чеклист соответствия

Минимальный перечень технических и организационных мер для соответствия законодательству РБ об обработке перс. данных:

Сбор данных

- Собираются только необходимые данные (принцип минимизации)
- Явное непредзаполненное согласие получено до начала сбора
- Факт согласия (дата, идентификатор, версия текста) зафиксирован в хранилище
- Цель обработки каждой категории данных задокументирована
- Политика обработки перс. данных опубликована

Хранение

- Пароли хранятся только в виде хэша с солью (bcrypt / argon2id / scrypt)
- Перс. данные в хранилище зашифрованы (column-level или TDE)
- Токены и ключи хранятся в виде хэша, не в открытом виде
- Реализовано удаление / необратимое обезличивание при закрытии аккаунта
- Бэкапы зашифрованы и хранятся физически отдельно
- Журнал доступа ведётся; перс. данные в логах минимизированы
- Срок хранения каждой категории данных задокументирован

Сеть

- HTTPS обязателен для всего трафика (TLS 1.2+)
- HTTP перенаправляет на HTTPS, HSTS включён
- СУБД недоступна из публичного интернета
- Firewall: открыты только необходимые порты
- SSH: аутентификация по ключу, парольный вход отключён
- Rate limiting / fail2ban настроены
- Защита от SQLi, XSS, CSRF реализована в приложении

Аппаратная часть

- Физический доступ к оборудованию с перс. данными ограничен
- Шифрование диска включено (BitLocker / FileVault / LUKS)
- ОС и все компоненты обновлены до актуальных версий
- Неиспользуемые сервисы отключены
- Процедура вывода оборудования из эксплуатации определена

Приложение и API

- Параметризованные запросы к СУБД (нет конкатенации)
- Секреты не в исходном коде и не в системе контроля версий
- MFA для административных аккаунтов

- Проверка прав авторизации на уровне сервера
- Реализованы: просмотр, изменение, удаление, экспорт данных пользователем
- Реализован отзыв согласия с прекращением обработки

Документы

- Политика обработки перс. данных опубликована
- Реестр обработки перс. данных составлен
- Акт классификации ИС подготовлен
- Политика информационной безопасности утверждена
- Журнал учёта инцидентов ведётся

Список использованных источников

[1] Закон Республики Беларусь от 7 мая 2021 г. № 99-З «О защите персональных данных». – Режим доступа: https://etalonline.by/document/?regnum=h12100099

[2] Приказ Оперативно-аналитического центра при Президенте Республики Беларусь от 20 февраля 2020 г. № 66 «О мерах по реализации Указа Президента РБ от 09.12.2019 № 449». – Режим доступа: https://www.oac.gov.by

[3] Приказ ОАЦ от 10 декабря 2024 г. № 259 (изменения в требованиях к системам защиты, EDR). – Режим доступа: https://www.oac.gov.by

Закон Республики Беларусь от 10 ноября 2008 г. № 455-З «Об информации, информатизации и защите информации».

[4] Кодекс Республики Беларусь об административных правонарушениях, статья 23.7.

[5] Национальный центр защиты персональных данных Республики Беларусь. – Режим доступа: https://cpd.by

[6] Классификация информационных систем РБ. – Режим доступа: https://redsec.by/article/pravovaya-osnova-i-klassifikaciya-informacionnyh-sistem-v-respublike-belarus/

[7] OWASP - Open Web Application Security Project Top 10. – Режим доступа: https://owasp.org/www-project-top-ten/

[8] NIST SP 800-88: Guidelines for Media Sanitization. – Режим доступа: https://csrc.nist.gov/publications/detail/sp/800-88/rev-1/final